Practice Questions

Candidate: Dunkan Gibson (dunkan.gibson)
Date: 11/15/2021 6:58:41 pm • Time spent: 02:53

Score: 83% Passing Score: 80%

Question 1: ✔ Correct

What is the primary countermeasure to social engineering?

- Traffic filters
- ➡ Awareness
- Heavy management oversight
- A written security policy

EXPLANATION

The primary countermeasure to social engineering is awareness. If users are unaware of the necessity for security in your organization and they are not properly trained to support and provide security, they are vulnerable to numerous social engineering exploits. Awareness training focused on preventing social engineering should include methods for authenticating personnel over the phone, assigning classification levels to information and activities, and educating your personnel on what information should not be distributed over the phone.

A written security policy is a countermeasure against social engineering, but without awareness training, it is useless. Heavy management oversight may provide some safeguards that protect users from social engineering, but management is less effective than awareness. Traffic filters are not countermeasures for social engineering because they do not focus on solving the human problem inherent in social engineering attacks.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 2: ✔ Correct

Which of the following are examples of social engineering? (Select two.)

- [ ] War dialing
- [ ] Port scanning
- [x] Dumpster diving
- [x] Shoulder surfing

EXPLANATION

Social engineering leverages human nature. Internal employees are often the target of trickery, and false trust can quickly lead to a serious breach of information security. Shoulder surfing and dumpster diving are examples of social engineering. Shoulder surfing is the act of looking over an authorized user's shoulder in hopes of obtaining an access code or credentials. Dumpster diving involves searching through trash or other discarded items to obtain credentials or information that may facilitate further attacks. These low-tech attack methods are often the first course of action that a hacker pursues.

Port scanning and war dialing are technical attacks that seek to take advantage of vulnerabilities in systems or networks.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 3: ✔ Correct

How can an organization help prevent social engineering attacks? (Select two.)

- [x] Publish and enforce clearly written security policies
- [ ] Utilize 3DES encryption for all user sessions
- [ ] Implement IPsec on all critical systems
- [x] Educate employees on the risks and countermeasures

EXPLANATION

User training and policy enforcement are the keys to preventing social engineering attacks. Many users are not aware of social engineering risks. Training raises awareness, provides clear instructions for dealing with and reporting suspicious activity, and directly supports all published security policies.

Technical countermeasures protect against automated attacks. Social engineering seeks to gain access by exploiting human nature.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 4: ✔ Correct

Users on your network report that they have received an email stating that the company has just launched a new website. The email asks employees to click the website link in the email and log in using their username and password. No one in your company has sent this email.

What type of attack is this?

- ➡ Phishing
- Man-in-the-middle
- Smurf
- Piggybacking

EXPLANATION

Phishing uses an email and a spoofed website to obtain sensitive information. In a phishing attack:

- A fraudulent message that appears to be legitimate is sent to a target.
- The message guides the target to a website that appears to be legitimate.
- The fraudulent website asks the victim to provide sensitive information, such as an account number and password.

Piggybacking refers to an attacker entering a secured building by following an authorized employee. A man-in-the-middle attack is used to intercept information passing between two communication partners. A Smurf attack is a DRDoS attack that spoofs the source address in ICMP packets.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 5: ✔ Correct

You have just received a generic-looking email that is addressed as coming from the administrator of your company. The email says that as part of a system upgrade, you need enter your username and password at a new website so you can manage your email and spam using the new service.

What should you do?

- Click on the link in the email and look for company graphics or information before you enter the login information.
- ➡ Verify that the email was sent by the administrator and that this new service is legitimate.
- Click on the link in the email and follow the directions to enter your login information.
- Delete the email.
- Open a web browser, type in the URL included in the email, and follow the directions to enter your login credentials.

EXPLANATION

You should verify that the email is legitimate and has come from your administrator. It is possible that the network administrator has signed up for a new service. If you ignore the message or delete it, you might not get the benefits the company has signed up for. However, the email might be a phishing attack. An attacker might be trying to capture personal information. By verifying the email with the administrator, you will be able to tell if it is legitimate.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 6: ✔ Correct

Which of the following is not a form of social engineering?

- A virus hoax email message
- Impersonating a manager over the phone
- Impersonating a user by logging on with stolen credentials
- Impersonating a utility repair technician

EXPLANATION

Impersonating a user by logging on with stolen credentials is not a social engineering attack. It is an intrusion attack made possible by network packet capturing or obtaining logon credentials through social engineering.

Impersonating someone over the phone or in person are easily recognizable forms of social engineering. A virus hoax email message is also a form of social engineering because it attacks people by exploiting common the weaknesses of fear and ignorance.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 7: ✕ Incorrect

What is the primary difference between impersonation and masquerading?

- One is a real-time attack, and the other is an asynchronous attack.
- One is used against administrator accounts, and the other is used against end user accounts.
- ~~One is easily detected, and the other is subtle and stealthy.~~
- ➡ One is more active, and the other is more passive.

EXPLANATION

The primary difference between these two access control attacks is that impersonation is more active, while masquerading is more passive.

Both impersonation and masquerading attacks can target type of user account. Both impersonation and masquerading attacks take place in real time. Neither impersonation nor masquerading attacks have an intrinsic quality of being easy or difficult to detect.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 8: ✔ Correct

Which of the following is a common social engineering attack?

- ➡ Hoax virus information emails
- Using a sniffer to capture network traffic
- Distributing false information about your organization's financial status
- Logging on with stolen credentials

EXPLANATION

Hoax virus information emails are a form of social engineering attack. This type of attack preys on email recipients who are fearful and will believe most information if it is presented in a professional manner. All too often, the victims of these attacks fail to double-check the information or instructions with a reputable third-party antivirus software vendor before implementing the recommendations. Usually, these hoax messages instruct the reader to delete key system files or download Trojan horses.

Social engineering relies on the trusting nature of individuals to incentivize them to take an action or allow an unauthorized action.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 9: ✔ Correct

Dumpster diving is a low-tech means of gathering information that may be useful for gaining unauthorized access or as a starting point for more advanced attacks. How can a company reduce the risk associated with dumpster diving?

- Secure all terminals with screensaver passwords.
- ➡ Establish and enforce a document destruction policy.
- Create a strong password policy.
- Mandate the use of Integrated Windows Authentication.

EXPLANATION

Dumpster diving is best addressed by a document destruction policy. All sensitive documents should be shredded or burned, and employees should be trained on the proper use of disposal equipment and the policies governing the disposal of sensitive information.

A strong password policy, authentication types, and screensaver passwords are not enough to prevent the risk associated with dumpster diving. Username and password complexity efforts are wasted if employees document and dispose of this information in an insecure fashion.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 10: ✕ Incorrect

A senior executive reports that she received a suspicious email concerning a sensitive internal project that is behind production. The email was sent from someone she doesn't know, and he is asking for immediate clarification on several of the project's details so the project can get back on schedule.

Which type of an attack best describes the scenario?

- MAC spoofing
- Passive
- ➡ Whaling
- ~~Masquerading~~

EXPLANATION

Whaling is a form of a social engineering attack that targets senior executives and high-profile victims. Social engineering is an attack that exploits human nature by convincing someone to reveal information or perform an activity.

Masquerading is convincing personnel to grant access to sensitive information or protected systems by pretending to be someone who is authorized and/or requires that access. Passive social engineering attacks take advantage of the unintentional actions of others to gather information or gain access to a secure facility. MAC spoofing is changing the source MAC address on frames sent by the attacker and can be used to hide the identity of the attacker's computer or to impersonate another device on the network.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 11: ✔ Correct

On your way into the back entrance of the building at work one morning, a man dressed as a plumber asks you to let him in so he can fix the restroom. What should you do?

- Tell him no and quickly close the door.
- Let him in and help him find the restroom. Then let him work.
- Let him in.
- ➡ Direct him to the front entrance and instruct him to check in with the receptionist.

EXPLANATION

You should direct him to the front entrance, where he can check in with the proper people at your organization. Letting him in without knowing if he should be there could compromise security. Turning him away would be unprofessional.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 12: ✔ Correct

Match the social engineering description on the left with the appropriate attack type on the right.

Phishing	Whaling	Spear phishing
✔ An attacker sends an email pretending to be from a trusted organization, asking users to access a website to verify personal information.	✔ An attacker gathers personal information about a target individual, who is a CEO.	✔ An attacker gathers personal information about a target organization.

Dumpster diving	Piggybacking	Vishing
✔ An attacker searches through an organization's trash for sensitive information.	✔ An attacker enters a secure building by following an authorized employee through a secure door without providing identification.	✔ An attacker uses a telephone to convince individuals to reveal their credit card information.

EXPLANATION

Specific social engineering attacks include the following:

Dumpster Diving

Dumpster diving is the process of looking in the trash for sensitive information that has not been properly disposed of.

Tailgating and Piggybacking

Piggybacking and tailgating refer to an attacker entering a secured building by following an authorized employee through a secure door and not providing identification. Piggybacking usually implies consent from the authorized employee, whereas tailgating implies no consent from the authorized employee.

Phishing

A phishing scam is an email pretending to be from a trusted organization, asking the user to verify personal information or send money. In a phishing attack:

- A fraudulent message that appears to be legitimate is sent to a target.
- The message requests that the target visit a fraudulent website (which also appears to be legitimate). Graphics, links, and websites look almost identical to the legitimate websites they are trying to represent.
- The fraudulent website requests that the victim provide sensitive information, such as an account number and password.

Common phishing scams include the following:

- A rock phish kit is a fake website that imitates a real website (such as banks, PayPal, eBay, and Amazon). Phishing emails direct you to the fake website to enter account information. A single server can host multiple fake sites using multiple registered DNS names. These sites can be set up and taken down rapidly to avoid detection.
- A Nigerian scam, also known as a 419 scam, involves email that requests a small amount of money to help transfer funds from a foreign country. For your assistance, you are to receive a reward for a much larger amount of money that will be sent to you at a later date.
- In spear phishing, attackers gather information about the victim, such as which online banks they use. They then send phishing emails for the specific bank.
- Whaling is another form of phishing that is targeted to senior executives and high-profile victims.
- Vishing is similar to phishing. But instead of an email, the attacker uses Voice over IP (VoIP) to gain sensitive information. The term is a combination of voice and phishing.
- Spear Phishing Spear phishing's goal is to gain access to information that will allow the attacker to gain commercial advantage or commit fraud. Spear phishing frequently involves sending seemingly genuine emails to all employees or members of specific teams.

REFERENCES

LabSim for Network Pro, Section 13.2.

Copyright © 2021 TestOut Corporation All rights reserved.